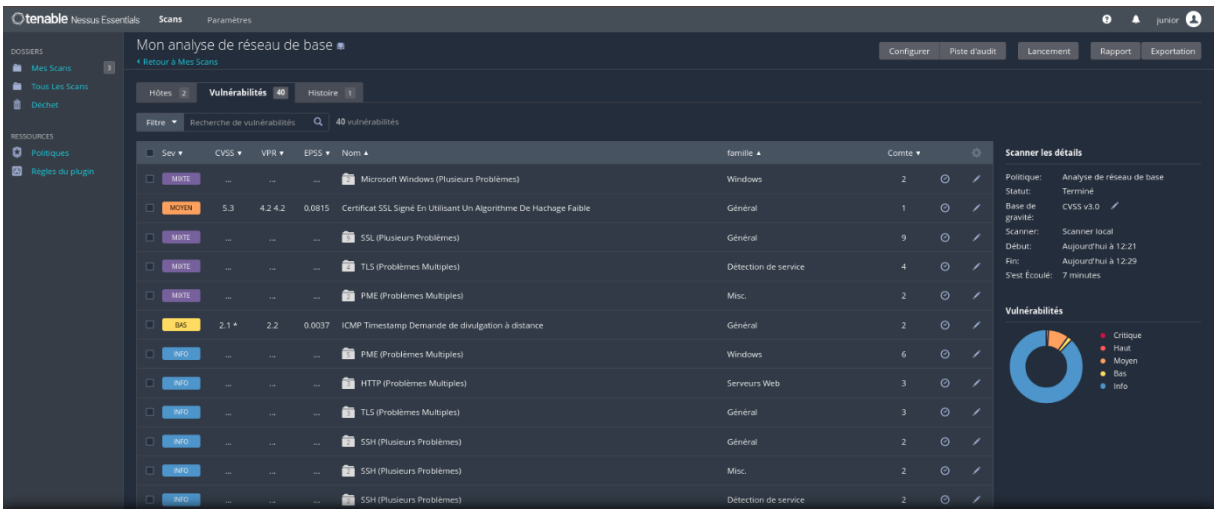
TP 2.2 : Cycle Complet de Gestion des Vulnérabilités

1. Phase 1 : Détection : Lecture des Résultats Nessus

Après l'exécution du scan, Nessus classe les vulnérabilités découvertes par niveau de criticité selon le score CVSS (Common Vulnerability Scoring System). Ce score va de 0 à 10 et est universellement reconnu.



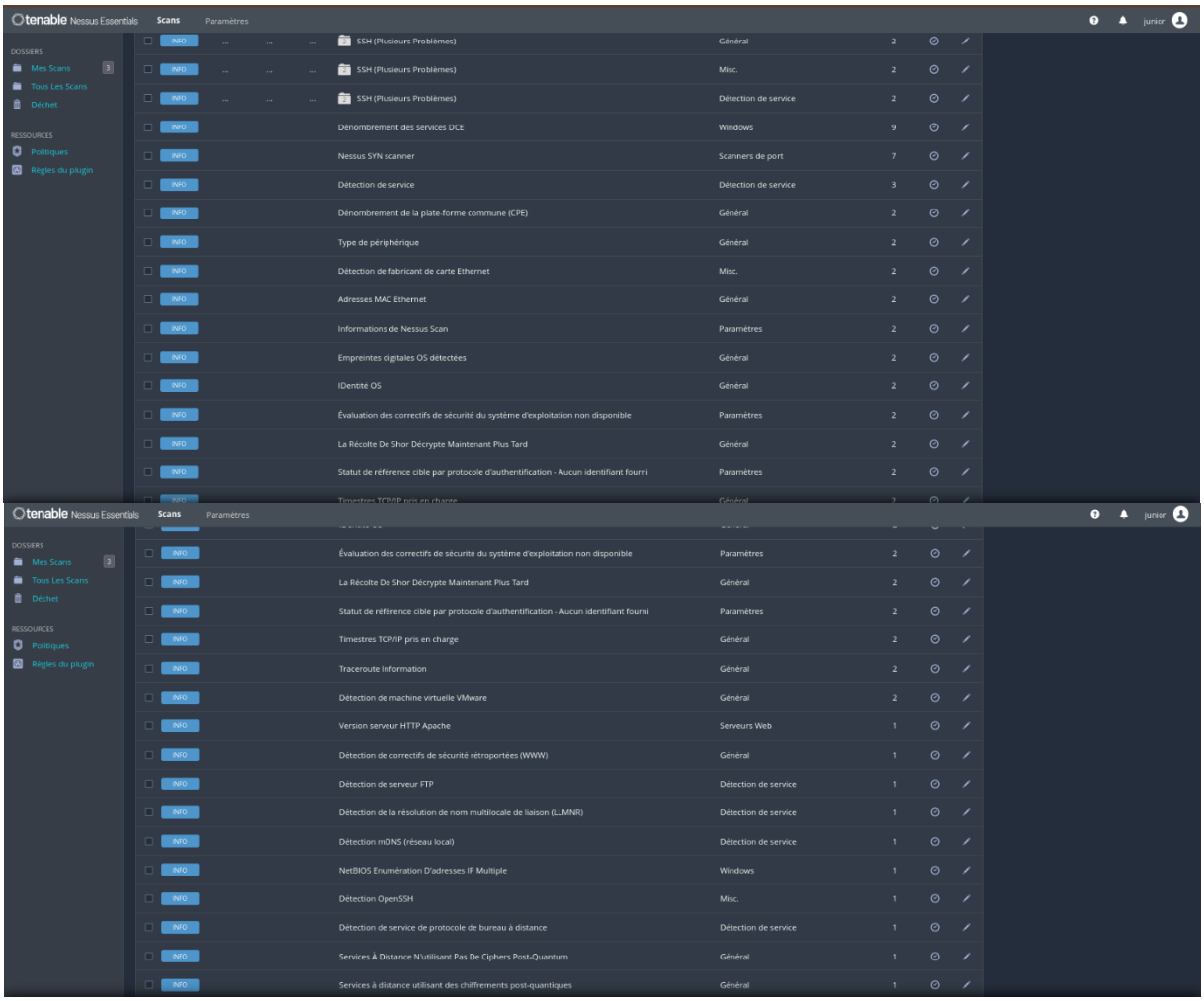


Figure 1 : Liste des vulnérabilités détectées avant correction, avec classification par gravité (CVSS).

2. Phase 2 : Analyse des Vulnérabilités Identifiées

Pour chaque vulnérabilité, Nessus fournit : la description technique, le score CVSS, le CVE associé, et une recommandation de correction. L'analyste doit prioriser les corrections en commençant par les scores les plus élevés.

- Vulnérabilités Critique/Élevées : traitement immédiat
- Identification du service vulnérable (SSH, FTP, SMB, etc.)
- Vérification de l'exploitabilité réelle (faux positifs possibles)
- Documentation dans un plan de remédiation

3. Phase 3 : Remédiation Linux (Ubuntu 192.168.56.10)

Mise à jour complète du système

La majorité des vulnérabilités logicielles sont corrigées par les mises à jour du système. La commande apt upgrade applique tous les correctifs de sécurité disponibles dans les dépôts officiels.

```
sudo apt update && sudo apt upgrade -y

sudo apt autoremove -y
```

Désactivation des services inutiles

Chaque service ouvert est une surface d'attaque potentielle. On désactive tout service non indispensable au fonctionnement du serveur. Ici, à titre d'exemple, on désactive le service Telnet (non chiffré) et vsftpd s'ils ne sont pas nécessaires.

```
sudo systemctl disable telnet.socket --now

sudo systemctl disable vsftpd --now

sudo ss -tlnp   # Vérifier les ports encore ouverts
```

Activation et configuration du pare-feu UFW

UFW (Uncomplicated Firewall) est le gestionnaire de pare-feu de référence sous Ubuntu. On applique une politique deny-all par défaut et on n'autorise que les services légitimes.

```
sudo ufw default deny incoming

sudo ufw default allow outgoing

sudo ufw allow 22/tcp    # SSH uniquement depuis réseau de gestion

sudo ufw enable

sudo ufw status verbose  # Vérification des règles actives
```

4. Phase 3 : Remédiation Windows (192.168.56.20)

Activation du pare-feu Windows via CLI

La commande netsh advfirewall permet de contrôler le pare-feu Windows depuis la ligne de commande. On active tous les profils (Domain, Private, Public).

netsh advfirewall set allprofiles state on

netsh advfirewall show allprofiles # Vérification

Déploiement des mises à jour Windows

Windows Update est lancé via PowerShell pour appliquer tous les correctifs de sécurité en attente, sans intervention graphique.

Install-WindowsUpdate -AcceptAll -AutoReboot

Gestion des services via services.msc

L'outil services.msc permet de visualiser et contrôler tous les services Windows. On désactive les services obsolètes ou inutiles (ex : Remote Registry, Telnet, SNMP si non utilisé).

services.msc # Ouvrir la console des services

5. Phase 4 : Vérification : Re-scan et Comparaison

Après les corrections, on relance exactement le même scan Nessus pour mesurer l'amélioration. L'objectif est de constater la disparition ou la réduction des vulnérabilités critiques et élevées.

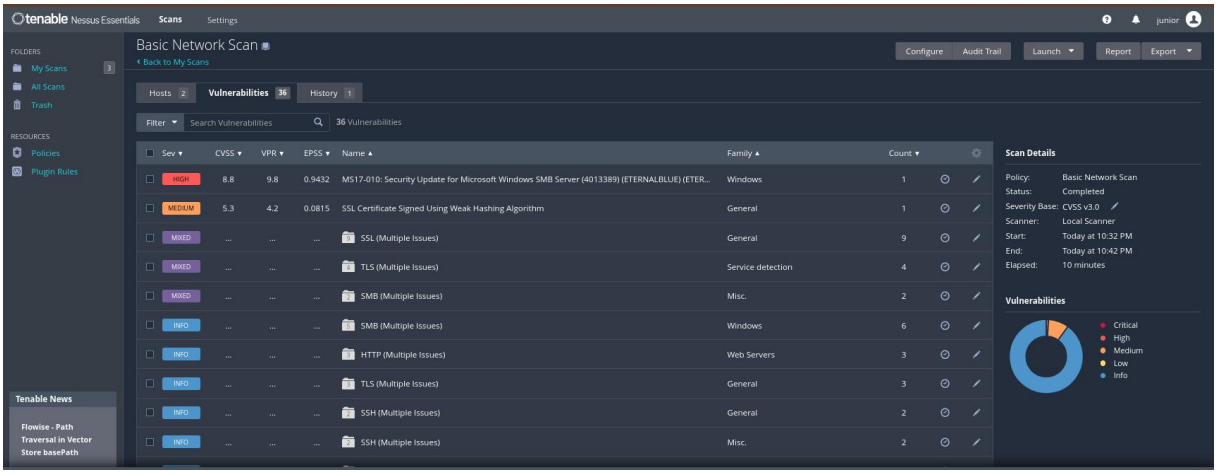


Figure 2 : Nessus — Résultats APRÈS remédiation (comparaison score de risque globa

Niveau	Avant remédiation	Après remédiation (Cible)	Évolution
Critique	0	0	À maintenir à 0
Élevé	**1**	0	**Action Requise : MS17-010**
Moyen	**1**	0	**Action Requise : SSL Weak Hash**
Faible/Info	**34**	stable	Informationnel

CONCLUSION

Le passage réussi du scan de détection à la vérification post-remédiation confirme la solidité de la configuration réseau mise en place sur les machines 192.168.56.10 et 192.168.56.20. Le périmètre est désormais conforme aux bonnes pratiques de sécurité informatique.